

development life cycle, allowing developers to address issues before they manifest into significant problems in the production environment.

Cost-effective security testing: By identifying vulnerabilities at the source code level, SAST tools help in reducing the cost of fixing security issues compared to identifying and resolving them at later stages of development or post-deployment.

Compliance with security standards: SAST tools assist organisations in adhering to security standards and regulations by proactively identifying and addressing security weaknesses in their applications.

Popular SAST tools with case studies

By analysing source code and detecting potential security weaknesses, SAST tools contribute to the enhancement of software security.

However, implementing a SAST tool can be challenging when dealing with a large codebase or legacy systems. The initial results of using a SAST tool may reveal a significant number of issues, which can be overwhelming for development teams. Overcoming these challenges requires a structured approach.

One notable case study involves the successful implementation of a SAST tool in a large codebase. By providing proper training to the development team, the organisation effectively optimised the effectiveness of the SAST tool. Through regular code checks and reiterative scanning of changed code segments, the organisation managed to address security vulnerabilities during the early stages of the development life cycle.

Here are some other examples and case studies showcasing the effectiveness of SAST tools.

- **Example: Checkmarx SAST tool**
Overview: Checkmarx is a leading SAST tool that offers comprehensive

static code analysis for identifying and fixing security vulnerabilities in custom source code. This tool is designed to seamlessly integrate with the development environment, providing real-time feedback to developers as they write code.

Case study: A prominent case study involving the implementation of Checkmarx SAST tool revealed a substantial improvement in the organisation's ability to detect and remediate security issues early in the software development life cycle. By leveraging the capabilities of Checkmarx, the organisation achieved a proactive security posture, resulting in the shipping of high-quality code with enhanced security.

- **Example: SonarQube for SAST capabilities**

Overview: SonarQube is an open source platform that offers continuous inspection of code quality, including automatic reviews with static analysis of code to detect bugs, code smells, and security vulnerabilities. SonarQube's SAST capabilities extend to analysing third-party libraries and dependencies in languages like Java, C#, and JavaScript/TypeScript.

Case study: In a notable case study, an organisation integrated SonarQube's SAST capabilities into their DevSecOps pipeline. By leveraging SonarQube's comprehensive reports, which encompass standards such as OWASP Top 10 and PCI DSS, the organisation maintained a clear view of their application's security posture. SonarQube's deeper SAST technology facilitated early detection and remediation of code quality and security concerns, ultimately reducing the risk of potential security breaches.

- **Example: Appknox SAST platform**
Overview: Appknox offers a streamlined SAST platform that proactively identifies vulnerabilities in mobile applications. The platform

provides a consolidated, user-friendly dashboard for securing Android or iOS mobile apps, delivering real-time feedback and comprehensive vulnerability details.

Case study: A case study involving the implementation of Appknox's SAST platform showcased its effectiveness in pre-emptively addressing potential security threats in mobile applications. The platform's ease of use, speed, and reliability empowered the organisation to enhance regulatory compliance and collaborate with the team on necessary improvements.

These examples and case studies highlight the significance of integrating SAST tools into the software development life cycle. By leveraging SAST tools such as Checkmarx, SonarQube, and Appknox, organisations can proactively address security vulnerabilities, cultivate a security-conscious development environment, and ensure the delivery of secure and resilient applications.

In the rapidly evolving landscape of cybersecurity, SAST tools have become indispensable for organisations and developers aiming to fortify their applications against potential security threats. By integrating SAST tools into the software development life cycle, organisations can proactively identify and rectify security vulnerabilities, thereby bolstering the security of their applications and safeguarding sensitive data. As the demand for secure software continues to rise, SAST tools are poised to remain an essential component of ensuring the integrity and security of applications in the digital age. **END** 🐧

References

- <https://snyk.io>
- <https://owasp.org>

By: Neetesh Mehrotra

The author is working in EY as a senior. His areas of interest are Java development and automation testing.